WEBSITE SECURITY ASSESSMENT REPORT

HTTP Security Header Configuration Review

Target Website: https://example.com
Assessment Type: Basic Non-Destructive Website Security Assessment
Final URL: https://example.com/
HTTP Status: 200 OK
Security Header Score: 0 / 4 (0%)
Overall Rating: WEAK

---

1. Executive Summary

A basic non-destructive security assessment was performed against the authorized test target, https://example.com, to review the presence of commonly recommended HTTP security headers.

The assessment checked four HTTP security headers:

- Content-Security-Policy
- X-Frame-Options
- Strict-Transport-Security
- X-Content-Type-Options

The assessment identified that all four tested security headers were missing from the HTTP response.

Security Header Score: 0/4 (0%)

Based on the defined scoring model, the configuration is rated **WEAK**.

A missing security header does not automatically mean that the website is exploitable. The findings should be reviewed in the context of the application's architecture, functionality, and overall security controls.

---

2. Scope

The scope of this assessment was limited to the publicly accessible HTTP response configuration of:

Target: https://example.com

The assessment focused specifically on the presence and basic configuration of selected HTTP security headers.

---

3. Assessment Methodology

The assessment was performed using a Python-based HTTP security assessment tool.

The tool:

1. Validated the target URL.
2. Connected to the target website over HTTPS.
3. Followed HTTP redirects.
4. Recorded the final URL and HTTP status code.
5. Reviewed selected HTTP response security headers.
6. Recorded whether each header was present or missing.
7. Calculated a security-header score.
8. Assigned an overall configuration rating.

The assessment was **non-destructive** and did not attempt to exploit vulnerabilities.

---

4. Assessment Results

4.1 HTTP Response Information

Target URL: https://example.com
Final URL: https://example.com/
HTTP Status Code: 200

4.2 Security Header Results

Security Header	Status	Security Purpose
Content-Security-Policy	MISSING	Helps reduce XSS and code-injection risks
X-Frame-Options	MISSING	Helps protect against clickjacking
Strict-Transport-Security	MISSING	Helps enforce HTTPS connections
X-Content-Type-Options	MISSING	Helps prevent MIME-type sniffing

Overall Score: 0/4 (0%)
Overall Rating: WEAK

---

5. Detailed Findings

Finding 01 — Content-Security-Policy Header Missing

Status: MISSING
Risk Area: Web Application Security

Description

The Content-Security-Policy (CSP) HTTP response header was not detected.

CSP allows a website to define which sources of scripts, styles, images, frames, and other content are permitted to load. A properly designed CSP can help reduce the impact of cross-site scripting (XSS) and other code-injection attacks.

Recommendation

Review the application's content requirements and implement an appropriate Content-Security-Policy that restricts trusted content sources.

The policy should be tested carefully before deployment to avoid breaking legitimate website functionality.

Finding 02 — X-Frame-Options Header Missing

Status: MISSING
Risk Area: Clickjacking Protection

Description

The X-Frame-Options HTTP response header was not detected.

This header can help prevent unauthorized framing of a website by other pages and can reduce the risk of clickjacking attacks.

Recommendation

Consider implementing an appropriate X-Frame-Options policy.

Where appropriate, modern deployments can also use the CSP `frame-ancestors` directive for more flexible framing control.

Finding 03 — Strict-Transport-Security Header Missing

Status: MISSING
Risk Area: HTTPS / Transport Security

Description

The Strict-Transport-Security (HSTS) HTTP response header was not detected.

HSTS can instruct compatible browsers to access a website only through HTTPS, helping reduce certain risks associated with insecure HTTP connections and protocol downgrade scenarios.

Recommendation

If the website is fully configured for HTTPS and all relevant subdomains are ready for HSTS, consider implementing Strict-Transport-Security with an appropriate policy.

The deployment should be carefully reviewed before enabling HSTS, particularly when using the `includeSubDomains` or preload options.

Finding 04 — X-Content-Type-Options Header Missing

Status: MISSING
Risk Area: Browser Security

Description

The X-Content-Type-Options HTTP response header was not detected.

The `nosniff` directive can help prevent browsers from incorrectly interpreting content types and can reduce certain MIME-type sniffing risks.

Recommendation

Consider adding:

```
X-Content-Type-Options: nosniff
```

The configuration should be tested to ensure that legitimate resources continue to be served with correct content types.

---

6. Security Score

The assessment uses a simple four-header scoring model.

- **4/4 (100%) — GOOD**
- **2-3/4 (50-75%) — NEEDS IMPROVEMENT**
- **0-1/4 (0-25%) — WEAK**

Assessment Score

0/4 (0%) — WEAK

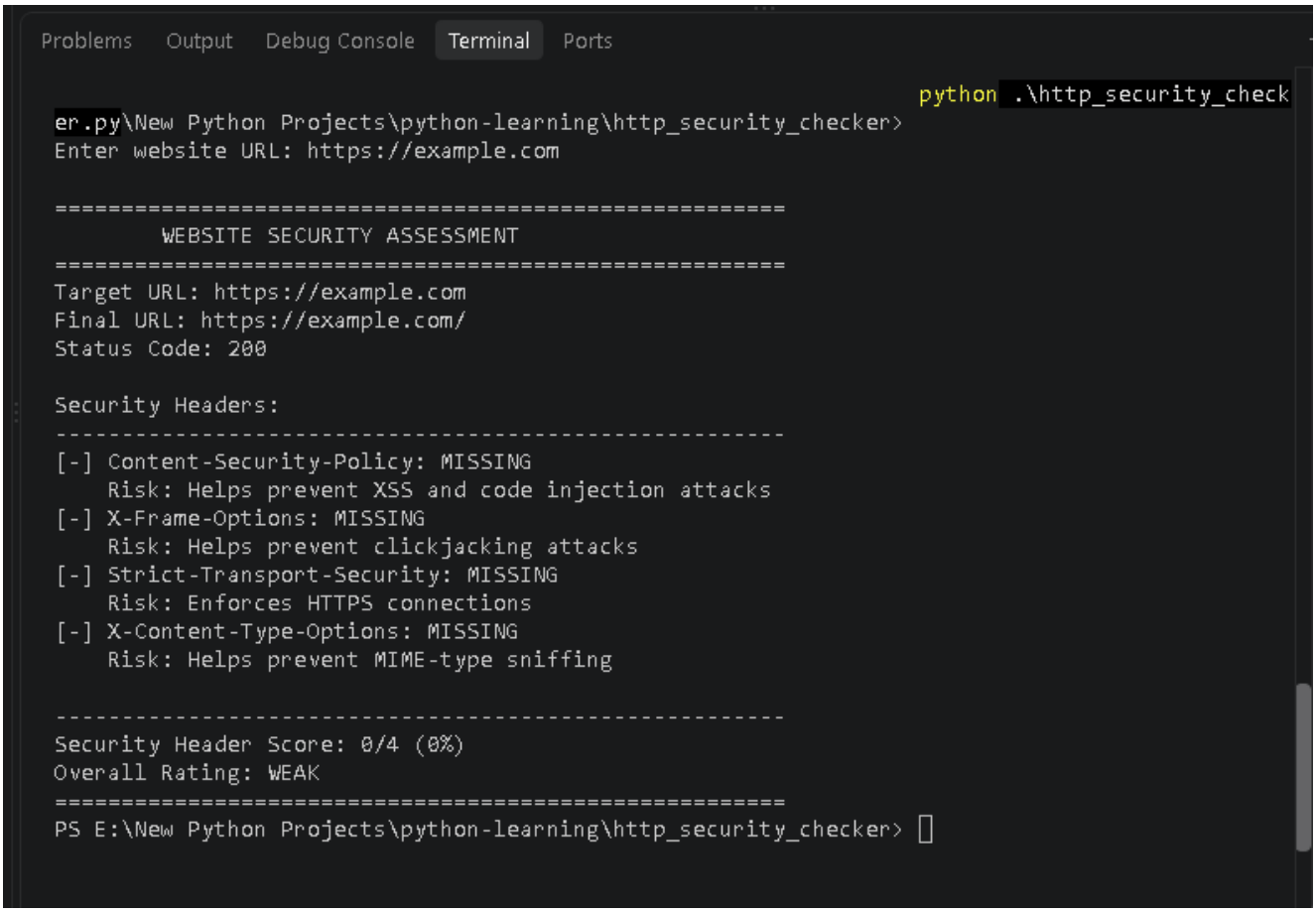
This score is intended as a quick HTTP security configuration indicator. It should **not** be interpreted as a complete penetration-test severity rating or a complete measurement of the website's overall security.

---

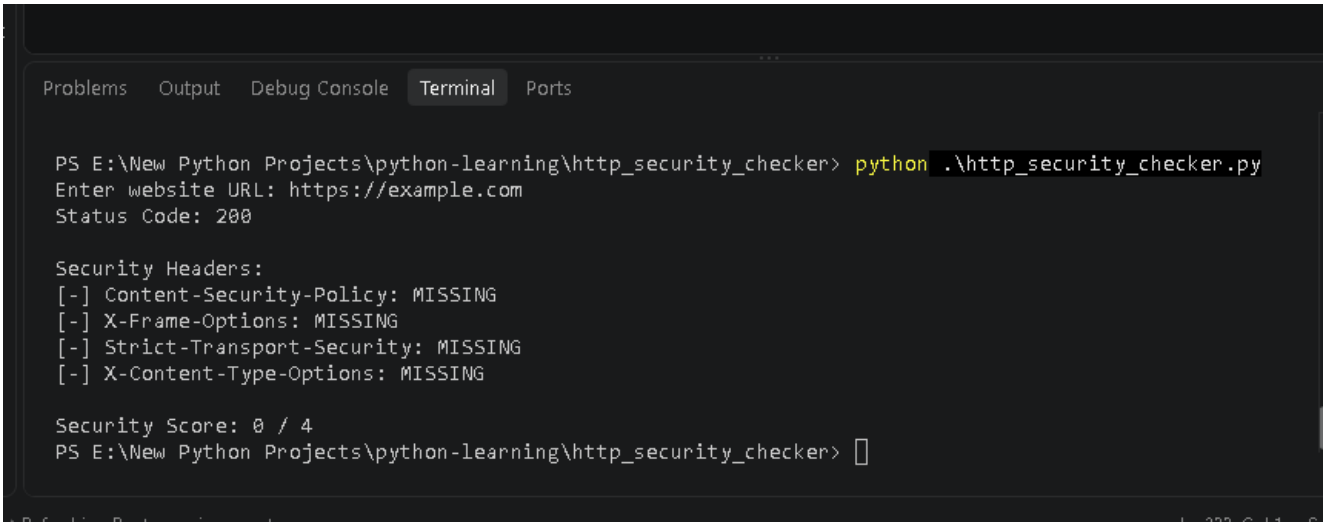
7. Evidence

The following screenshots were captured during the assessment:

Evidence 01:
`example_com_security_assessment.png`



Evidence 02:
`http_security_checker_example_com.png`



These screenshots demonstrate the assessment output and security-header results produced by the assessment tool.

---

8. Limitations

This assessment was limited to a basic automated review of selected HTTP response headers.

The assessment did not include:

- Source-code review
- Authentication testing
- Authorization testing
- Exploitation of vulnerabilities
- Database testing
- Password testing
- Denial-of-service testing
- Business-logic testing
- Full OWASP penetration testing
- Authenticated application testing
- Infrastructure penetration testing
- Compliance auditing

Therefore, this report should not be considered a full penetration-test report.

---

9. Recommended Remediation Priority

The following actions are recommended for further security review:

Priority 1 — Review CSP

Design and test an appropriate Content-Security-Policy based on the website's legitimate content sources.

Priority 2 — Review Clickjacking Protection

Consider implementing X-Frame-Options and/or an appropriate CSP `frame-ancestors` policy.

Priority 3 — Review HSTS

If HTTPS is correctly implemented across the required scope, consider deploying an appropriate Strict-Transport-Security policy.

Priority 4 — Enable MIME-Type Protection

Consider implementing:

```
X-Content-Type-Options: nosniff
```

---

10. Conclusion

The assessment identified four missing HTTP security headers on the tested target.

The resulting security-header score was:

0/4 (0%) — WEAK

The identified configuration gaps should be reviewed and remediated according to the application's architecture and security requirements.

Implementing appropriate security headers can strengthen browser-side security controls; however, HTTP security headers are only one part of a comprehensive web application security program.

A complete security assessment would require additional testing covering application functionality, authentication, authorization, input validation, access control, server configuration, dependencies, and other relevant security controls.

---

11. Ethical Use Statement

This assessment was performed for educational and authorized security-assessment purposes.

Security testing should only be conducted against websites, systems, and applications that you own or have explicit permission to assess.

Unauthorized security testing may be illegal and may cause disruption or damage.

Assessment Tool

Tool: Website Security Assessment Tool
Technology: Python
Assessment Type: Non-Destructive HTTP Security Header Review

Project Repository:
https://github.com/coolzafry83-coder/python-learning

Report Prepared For Portfolio Demonstration

Assessment Focus: Website Security Configuration
Report Type: Sample Security Assessment Report
Target: https://example.com
Result: 0/4 Security Headers Detected